



End to End Encryption

Partha Das Chowdhury

October 11, 2023

bristol.ac.uk

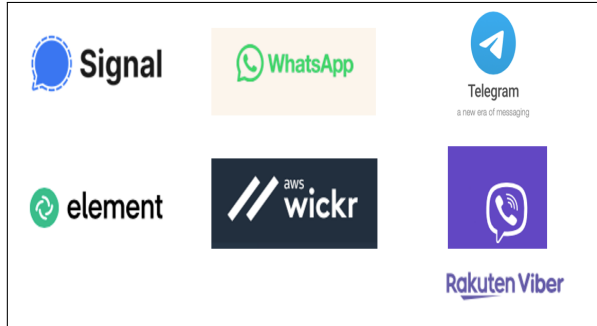
End to End Encrypted Messaging Applications

- ✶ There are many entities that have an interest in an instance of a communication
- ✶ They should be legitimate and indiscernible

“Authentication is knowing where something came from, and confidentiality is knowing where it went to”

Butler Lampson

Popular E2EE messaging applications



Background – E2EE Messaging App

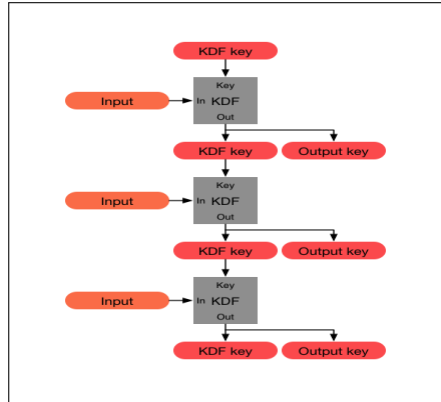
- ✶ The identity key (IK) pair is the root of trust for every account in a mobile device
- ✶ Short lived keys are used for communication between entities in a communication
- ✶ The short-lived keys are signed by IK and communicated to the server
- ✶ The assumption is that apart from the legitimate owner no one else can prove possession of IK

Background – E2EE Messaging App

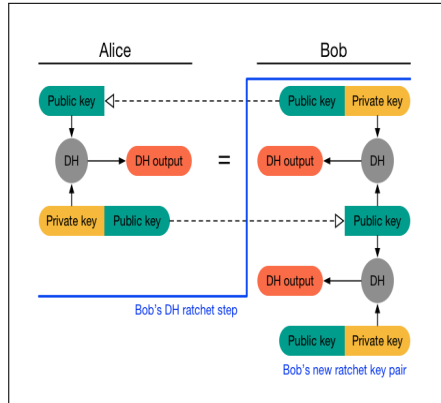
Applications	Protocol	Primary Device (Phone) Parameters	Desktop Client
Signal	Signal	Curve25519 Key pair – Long term Identity Key Curve25519 Key pair – Pre-Keys	Desktop ID authenticated by primary device. Can be used independently.
WhatsApp	Signal	Curve25519 Key pair – Long term Identity Key Curve25519 Key pair – Pre-Keys	Desktop ID authenticated by primary device Can be used independently
Element	Olm-Double Ratchet Implementation	Curve25519 Key pair – Long term Identity Key Curve25519 Key pair – Pre-Keys	Desktop ID authenticated by primary device. Can be used independently.
Wickr Me	Wickr Secure Messaging Protocol	Curve P521 Key pairs SHA-256 Device Identifier	Desktop ID authenticated by primary device Can be used independently.
Viber	Double Ratchet Implementation	Curve25519 Key pair – Long term Identity Key	Desktop client authenticated by primary device Can be used independently.
Telegram	MTPROTO 2.0 – Diffie Hellman Implementation	Cloud chat – 2048 bit permanent key Secret Chat – DH keys between communicating entities.	Desktop ID authenticated by primary device Can be used independently.

TABLE I: Properties of Popular Messaging Applications

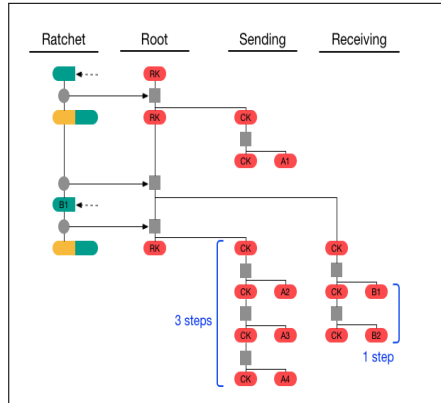
Symmetric Key Ratchet - KDF



DH Ratchet



Double Ratchet



Key Steps

- ✿ A & B agree on a root key using X3DH
- ✿ $A \rightarrow B: g^x$ where x is known to only A
- ✿ $B \rightarrow A: g^y$ where y is known to only A
- ✿ They both do g^{xy}
- ✿ Each participant has a sending chain and a receiving chain.
- ✿ Alice's sending chain is same as Bob's receiving chain. They advance with each message.
- ✿ Every message must contain the sender's current public share.

A Paper we Wrote

Threat Models over Space and Time: A Case Study of E2EE Messaging Applications

Partha Das Chowdhury*, Maria Sameen*, Jenny Blessing[†], Nicholas Boucher[†], Joseph Gardiner*, Tom Burrows[†],
Ross Anderson^{†‡}, Awais Rashid*

*University of Bristol, UK {*partha.daschowdhury, maria.sameen, joe.gardiner, awais.rashid*}@bristol.ac.uk

[†]University of Cambridge, UK. {*jenny.blessing, nicholas.boucher, ross.anderson*}@cl.cam.ac.uk, *tom@tpmb.uk*

[‡]University of Edinburgh, UK *ross.j.anderson@ed.ac.uk*

Related Work

- ✿ Cremers, C., Fairoze, J., Kiesl, B. and Naska, A., 2020, October. Clone detection in secure messaging: improving post-compromise security in practice. In Proceedings of the 2020 ACM SIGSAC Conference on Computer and Communications Security (pp. 1481-1495).
- ✿ Albrecht, M.R., Celi, S., Dowling, B. and Jones, D., 2023. Practically-exploitable cryptographic vulnerabilities in Matrix. Cryptology ePrint Archive

Findings

Signal

- ✳ Desktop client threat model persists with the mobile application threat model
- ✳ Access to the database decryption keys can render de-linking inconsequential

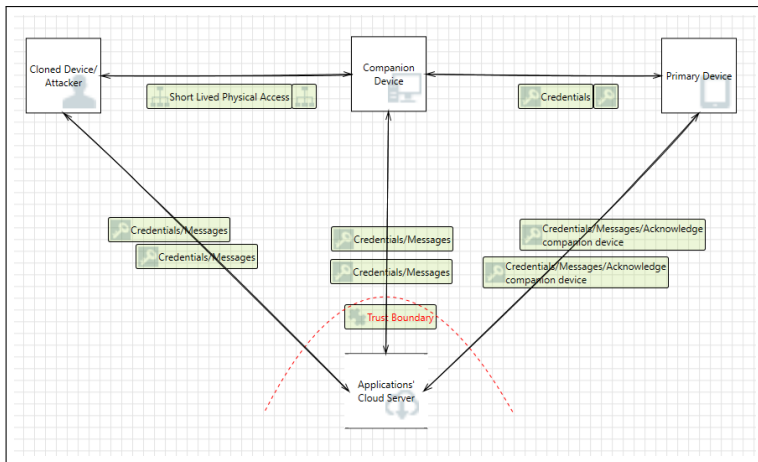
WhatsApp

- ✳ Desktop client recognizes that there can be malicious insiders
- ✳ Cloning is possible, yet improved alerts and time out does marginally better than Signal

Telegram

- ✳ Cloning is easy & persists with the eavesdropper only threat model
- ✳ There is a possibility to set time outs

DFD for Signal, WhatsApp & Telegram Desktop Applications



Viber

- ✖ Scopes threats from malicious insiders. Explicitly pins primary ID into companion devices
- ✖ Users are not responsible for detecting and recovering from threats

Element

- ✖ Cloning through short lived access is possible, attacker can see communicating entities
- ✖ Does not break forward secrecy

Wickr Me

- ✖ Ties a device with the cryptographic identity. Adequately scoped emergent threats
- ✖ Does not depend on the user to detect & recover from a breach

DFD for Element, WickrMe & Viber Desktop Applications

